

// кейс КРОК: Сканер утечек в коде

DevSecOps, Secure Coding

описание:

Разработайте инструмент для поиска утечек секретов в локальном проекте. Решение должно находить API-ключи, токены и другие чувствительные данные по типовым паттернам, ранжировать находки по уровню критичности и формировать отчёт с указанием файла, строки и типа потенциальной утечки.

// содержание кейса

область:

Безопасная разработка (Secure Coding), DevSecOps, автоматизация процессов обеспечения информационной безопасности в разработке программного обеспечения.

проблема:

- Случайное попадание чувствительных данных в исходный код или конфигурационные файлы
- Риск публикации секретов в системах контроля версий или публичных репозиториях
- Сложность контроля безопасности в больших проектах и командах при ручной проверке кода
- Недостатки автоматизированных инструментов для анализа кода и выявления потенциальных утечек секретов

стейкхолдеры:

- Разработчики программного обеспечения
- DevOps / DevSecOps инженеры
- Специалисты по информационной безопасности
- Руководители команд разработки
- Инженеры сопровождения инфраструктуры

что будет, если не решать проблему:

Попадание секретов в исходный код может привести к несанкционированному доступу к инфраструктуре, утечке данных, компрометации сервисов, финансовым потерям и репутационным рискам. Подобные инциденты регулярно происходят даже в крупных компаниях и часто становятся причиной серьезных инцидентов.

как сейчас решается проблема:

- Использование GitLeaks, TruffleHog, detect-secrets и аналогов
- Встроенные механизмы сканирования секретов в системах контроля версий
- Интеграция проверок в CI/CD-пайплайны
- Использование систем управления секретами (HashiCorp Vault, AWS Secrets Manager, GitLab CI variables)
- Применение DLP-подходов для контроля утечек чувствительной информации
- Внедрение практик Shift-Left DevSecOps
- Ручной контроль в рамках code review

// ожидаемое решение

Участникам необходимо разработать инструмент, который анализирует локальный проект и выявляет потенциальные утечки секретов в исходном коде и конфигурационных файлах.

минимальный функционал решения:

- Сканирование файлов проекта (исходный код, конфигурационные файлы, скрипты и т.п.)
- Поиск потенциальных секретов по типовым паттернам (API-ключи, токены доступа, приватные ключи, строки, похожие на base64-закодированные данные)
- Определение уровня критичности обнаруженной находки
- Формирование отчета, содержащего:
 - путь к файлу,
 - номер строки,
 - тип обнаруженного секрета,
 - уровень риска

дополнительно приветствуется:

- Поддержка различных типов файлов
- Настройка пользовательских правил поиска
- Рекомендации по устранению найденных проблем (например, перенос секретов в переменные окружения или систему управления секретами)

Решение должно работать локально и не требовать подключения к внешним сервисам. Формат реализации (CLI-утилита и/или веб-интерфейс) выбирается участниками самостоятельно.

что нужно сделать:

- Проанализировать проблему утечек секретов в исходном коде и определить типовые сценарии их появления
- Разработать инструмент для автоматического сканирования локального проекта и поиска потенциальных секретов (API-ключей, токенов, паролей, приватных ключей и др.)
- Реализовать механизм выявления секретов по типовым паттернам и правилам поиска
- Реализовать формирование отчета по результатам сканирования (файл, строка, тип обнаруженного секрета, уровень критичности)
- Предложить рекомендации по устранению обнаруженных утечек (например, перенос секретов в переменные окружения или системы управления секретами)
- Продемонстрировать работу инструмента на тестовом проекте с добавленными примерами потенциальных утечек